

Crypto & Architecture

CompTIA Security+ · SY0-701 · Cheat Sheet

// Cryptographic Solutions & Mitigation / Security Architecture

HOW TO USE THIS: Two domains trip people up most. This sheet covers them both. Read the Exam Patterns callouts first – they're the scenario reasoning the exam tests. Then drill the tables until the algorithm-to-goal mapping is automatic.

01 — CRYPTOGRAPHIC SOLUTIONS

EXAM PATTERN: Every crypto scenario tests which security GOAL a tool serves.
Encryption → Confidentiality Hashing → Integrity Digital Signature → Integrity + Authentication + Non-repudiation PKI → Enables all of the above

Symmetric vs Asymmetric

Type	Key Structure	Speed	Use Case	Examples
Symmetric	One shared key	FAST	Bulk data, disk encryption, VPN	AES, ChaCha20, 3DES (legacy)
Asymmetric	Public + Private Key pair	Slower	Key exchange, digital signatures	RSA, ECC/ECDSA, Diffie-Hellman
Hybrid	Both – asym. for key exchange, sym. for data	Fast in practice	HTTPS, SSH	TLS 1.3: ECDH + AES-GCM

Algorithm Quick Reference

Algorithm	Type	Key/Output Size	Primary Use
AES-256	Symmetric block	256-bit key	Disk encryption, VPN, TLS data
ChaCha20	Symmetric stream	256-bit key	Mobile/IoT where AES-NI unavailable
3DES	Symmetric block	168-bit effective	Legacy only – avoid in new systems
RSA	Asymmetric	2048–4096-bit key	Key exchange, signatures (slow)
ECC / ECDSA	Asymmetric	256-bit ≈ RSA 3072	Mobile, IoT, certificates – same strength, smaller key
Diffie-Hellman	Key exchange	Variable	Establish shared secret over public channel
SHA-256 / SHA-3	Hash	256-bit output	File integrity, password hashing, certs

Algorithm	Type	Key/Output Size	Primary Use
HMAC	Hash + shared key–		Message auth – proves sender knows the key
bcrypt / Argon2	Key stretching –		Password storage – deliberately slow, salted

Digital Signatures — How It Actually Works

1. Alice HASHES the message (SHA-256 → digest) 2. Alice ENCRYPTS the hash with her PRIVATE KEY = Signature 3. Bob receives message + signature 4. Bob DECRYPTS signature with Alice's PUBLIC KEY = recovers hash 5. Bob independently hashes the message 6. If hashes MATCH → message is authentic and unmodified Provides: Authentication (Alice's private key signed it) + Integrity (hash matches) + Non-repudiation (only Alice has her private key) Does NOT provide: Confidentiality – encrypt separately if needed

PKI (Public Key Infrastructure)

Component	Description
Root CA	Self-signed apex of trust. Should be OFFLINE / air-gapped. Signs intermediate CAs only.
Intermediate CA	Signed by root. Online. Issues end-entity certificates. Compromise isolated from root.
Certificate	Binds public key to identity. Contains: subject, SAN, validity period, key usage, issuer.
CSR	Certificate Signing Request – entity generates keypair, sends public key + info to CA for signing
CRL	Certificate Revocation List – periodic list of revoked certs. Can be stale between publications.
OCSP	Real-time single-cert revocation check. Better than CRL for freshness.
OCSP Stapling	Server caches OCSP response and presents it in TLS handshake. Reduces OCSP server load.
Wildcard cert	*.domain.com – covers all subdomains. One compromise = all subdomains exposed.
SAN cert	Subject Alternative Name – lists specific FQDNs. More granular and secure than wildcard.
Key Escrow	A copy of a private key held by trusted third party for recovery or lawful access.

Passwords: Salting & Key Stretching

Salt: Random value appended to a password before hashing. Stored alongside the hash. Even if two users have "Summer2023", their hashes differ. DEFEATS rainbow tables. **Key Stretching (bcrypt, PBKDF2, Argon2):** Adds a configurable work factor (iterations). Brute-force is slowed proportionally – 1M guesses/sec becomes impractical. Argon2 is the current winner for new systems.

02 — MITIGATION & SECURITY ARCHITECTURE

EXAM PATTERN: Architecture & mitigation questions are **SCENARIO-BASED**. The exam gives a constraint (budget, environment type, threat vector) and asks which control fits. Zero Trust is heavily tested for 701. Know the control plane components by name.

Mitigation Techniques — Scenario Mapping

Technique	What It Does	When Exam Picks It
Segmentation	Divides network into isolated zones (VLANs, subnets, DMZ)	Confined attack surface; isolate IoT/OT from corporate network
Micro-segmentation	Granular workload-level segmentation	Zero trust data traffic; prevent lateral movement between servers
Hardening	Disable unused ports/services, remove defaults	Reduce attack surface before going live
Patching	Apply vendor fixes to known CVEs	Vulnerability management; specific CVE mentioned in scenario
Least Privilege	Grant minimum permissions needed to do job	Insider threat; privilege escalation; role change scenario
Access Control	RBAC/ABAC/MAC/DAC enforce who can do what	Prevent accessing sensitive data; need-to-know enforcement
Isolation/Sandbox	Run untrusted code in contained environment	Malware analysis; legacy app; suspicious executable
Encryption at Rest	Protect stored data if media is stolen	Storage theft; decommissioned drive; stolen backup tape
Encryption in Transit	TLS/HTTPS protects data on the wire	MITM attack; plaintext credential capture on Wi-Fi
Monitoring/SIEM	Centralized log collection and correlation	Incident response; detection; compliance; anomaly alerting
Deception (Honeypot)	Fake systems to detect attackers	Incident response; detect lateral movement post-breach

Access Control Models

Model	How Access Is Decided	Pick When...
RBAC	Permissions assigned to roles; users get access via role	Scenario says "based on job role" – most common in enterprise
ABAC	Access based on multiple attributes (user, time, location, etc.)	Multiple dynamic conditions in scenario; fine-grained policy
MAC	Security labels (Top Secret / Secret / Unclassified) enforced	Military or government classification scenario
DAC	Resource owner controls access (like file system permissions)	User shares permissions; owner grants access directly

Zero Trust Architecture

Core principle: Never trust, always verify. No implicit trust based on network location. Every access request must be authenticated, authorized, and continuously validated – whether the request comes from inside or outside the perimeter. **vs. Traditional (perimeter/castle-and-moat):** Once inside the firewall, you're trusted. Zero Trust eliminates this assumption entirely.

ZT Component	Role
Policy Engine (PE)	Brain. Evaluates every access request against policy, user risk score, device health, and context.
Policy Administrator (PA)	Issues or revokes session tokens based on Policy Engine decision. Gateway to access.
Policy Enforcement Point (PEP)	Gatekeeper on data plane. Allows or blocks actual traffic based on PA token. Where enforcement happens.
Adaptive Identity	Trust score adjusts dynamically. Unusual behavior (new country, odd hours) triggers step-up MFA.
Micro-segmentation	Controls east-west (lateral) traffic between workloads. No implicit trust between servers on same network.
Control Plane	Policy Engine + Policy Administrator. Makes decisions.
Data Plane	Policy Enforcement Point. Executes decisions on real traffic.

Cloud Service Models & Shared Responsibility

Model	Customer Manages	Provider Manages	Security Implication
IaaS	OS, middleware, runtime, applications	Physical hardware, hypervisor, network	Customer responsible for OS patching, firewall config, and app security.
PaaS	Application code, data	OS, runtime, middleware + backend services	Customer must secure app logic and data; provider secures infrastructure.
SaaS	Data, user access	Everything else	Customer: configure access controls, classify data. Provider: secures the service.

ICS / SCADA / IoT Security

Why ICS is different: Proprietary OS, often unpatched (patching breaks vendor certification or causes downtime), 24/7 operations, physical safety consequences of failure. Mitigations: Air-gap or network segmentation (OT on separate VLAN). Passive monitoring only – active scanning can crash PLCs. Unidirectional security gateways (data diodes). Strict change control for any updates. IoT mitigations: Change default credentials. Disable unused services/ports. Segment IoT onto dedicated VLAN. Keep firmware updated. Prefer ECC over RSA for constrained devices.

Defense in Depth vs Zero Trust

Principle	Core Idea	Exam Trigger Words
Defense in Depth	Layered controls across technical, administrative, physical	"multiple layers", "defense in depth", "if one firewall fails"
Zero Trust	No implicit trust. Verify every request regardless of location	"never trust, always verify", "identity-based", "continuous verification"
Least Privilege	Minimum access needed for the role. Not more	"need to know", "role change", "excessive permissions"
Separation of Duties	Sensitive tasks divided among multiple people	"single point of failure", "checks and balances", "fraud prevention"

03 — SCENARIO DECISION GUIDE

Cryptographic Scenario Patterns

If the scenario says...	The answer is...	Why
"Bulk data / disk / fast encryption"	Symmetric	Symmetric = fast, designed for bulk data
"Mobile or IoT, limited battery"	ECC (asymmetric)	ECC = small keys, low compute overhead
"Prove who sent it + not tampered"	Digital Signature	Auth + Integrity + Non-repudiation
"Real-time certificate revocation"	OCSP (not CRL)	OCSP = real-time; CRL = periodic/stale
"Two users same password, different hashes"	Salt	Salt makes identical passwords hash differently
"Brute-force resistant password storage"	Argon2	Key stretching = work factor slows brute-force
"Key stored in hardware, never exposed"	HSM	Hardware Security Module = keys never leave plaintext
"Data hidden inside an image file"	Steganography	Hides existence, not just meaning
"Key recovery if employee leaves"	Key Escrow	Third-party holds copy of private key

Architecture Scenario Patterns

If the scenario says...	The answer is...	Why
"IoT / OT on same network as workstations"	Segmentation / VLAN isolation	Limit blast radius; unpatched devices isolated
"New server before going live"	Hardening	Disable defaults, close ports, patch before production
"Run suspicious exe safely"	Sandboxing / isolation	Contained environment prevents real-system impact
"Detect attacker already inside"	Honeypot	Decoy with no legit traffic = any access = alert
"Never trust, always verify + identity"	ZT	Explicit ZT language in question
"Trust score changes based on behavior"	Dynamic Identity (ZT)	Dynamic trust in ZT model
"Provider manages OS, customer manages app"	Shared responsibility	Shared responsibility – PaaS boundary
"Military classification labels"	MAC	Mandatory Access Control = label-based
"Based on job role"	RBAC	Role = RBAC; attributes = ABAC
"Multiple overlapping controls"	Defense in Depth	Layered redundant controls

// Good luck on the exam – you got this.